

ICTICT443 Work collaboratively in the ICT industry

VU23220 Develop and carry out a cyber security industry project

Learner version

Assessment task 2

Task 2: Cyber Security Group Project (practical task)

Disclaimer: This resource was developed by Holmesglen Institute of TAFE in 2024 for the State of Victoria (Department of Education and Training) for educational purposes, is © State of Victoria (Department of Education and Training) and is available under a Creative Commons Attribution Non-commercial 4.0 International ([CC BY-NC 4.0](https://creativecommons.org/licenses/by-nc/4.0/)) license.

The license does not apply to: Trademarks or branding, including the Victorian Government logo and any unattributed content supplied by third parties

Student – Kelly Lindsay

Student number – 100694303

Executive Summary

The following penetration test was conducted on a simulated vulnerable server machine offered by the client, Holmesglen TAFE, for assessment purposes. The test was performed by Kelly Lindsay, a cybersecurity student at Holmesglen TAFE. The tester will be performing a controlled penetration test using a Kali Linux virtual machine as the attack platform. The tester will use penetration testing methodologies including reconnaissance with tools such as Nmap, port scanning to identify vulnerabilities and Metasploit to exploit the server with the overall goal to gain both root-level and user-level access to the target system.

Testing Scope and Methodology

Extent of Testing

Holmesglen Tafe enlisted the tester to perform a controlled penetration test against a vulnerable server hosted within a virtual lab environment. The primary objective of the penetration test was to identify and exploit security vulnerabilities in the target system to gain root-level and user-level access.

The test was conducted within an isolated network and included the following penetration activities:

- Network-level, technical penetration testing against a vulnerable virtual machine.
- Host discovery and enumeration using tools such as Netdiscover and Nmap.
- Service and port scanning to identify potential vulnerabilities.
- Exploitation of vulnerabilities using Metasploit.
- Post-exploitation and privilege escalation through the discovery of user credentials.

Test Scope Summary

The scope of this penetration test was isolated to the virtual environment between the Kali Linux machine and the vulnerable target server provided by Holmesglen TAFE. The test is for training purposes and is designed to simulate a real-world target with known security flaws. The testing environment consisted of:

- Internal Virtual Network: The vulnerable server and the attack machine (Kali Linux) were hosted within the same internal VMware network, isolated from external systems.

No external systems, users, or live production environments were involved in this test. All activities were performed ethically and within the boundaries of a controlled, non-production setup.

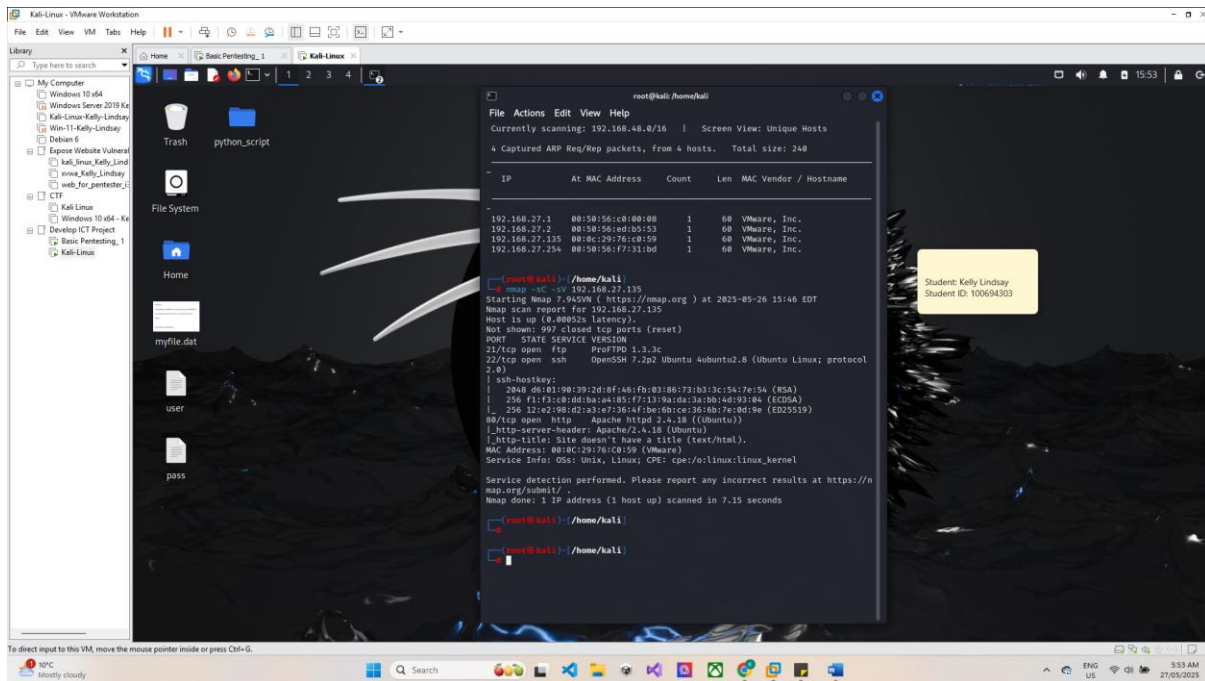
HOST DISCOVERY PHASE

NETDISCOVER

Netdiscover was used to uncover the target system's IP address - 192.168.27.135

NMAP

Nmap was then used to scan for ports on 192.168.27.135 – nmap -sC -sV 192.168.27.135



This provided a thorough list of ports to target, including port 21, 22 and 80.

VERIFY CONNECTIVITY

Ping tests were performed to confirm that the identified host was reachable and responsive.

RECONNAISSANCE PHASE

A list of significant ports were discovered and service version detection indicated a potentially vulnerable version of the ProFTPD 1.3.3c service running on port 21, which became the primary point of focus for exploitation.

IDENTIFY PORTS OPEN

Port 21 – used by FTP (File Transfer Protocol) but can be vulnerable due to misconfigurations and issues like anonymous login or backdoors – these can be a foothold for privilege escalation.

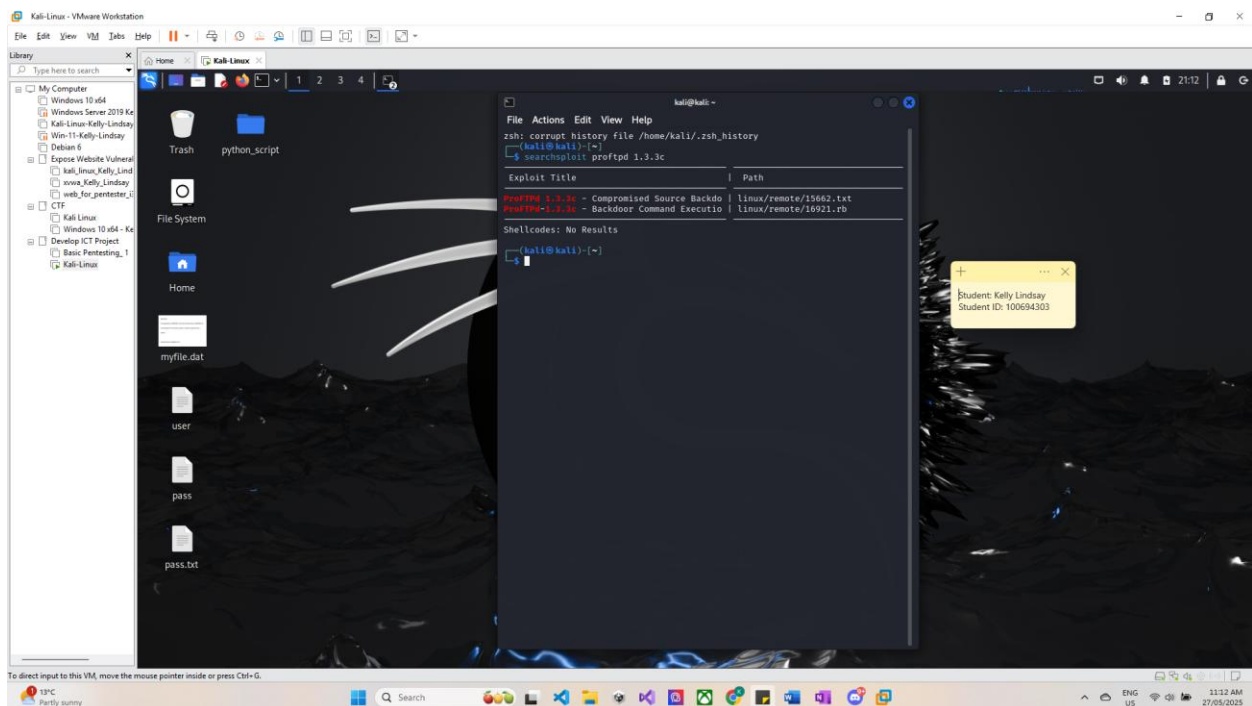
Port 22 – represents SSH (Secure Shell), which can be used for secure remote access but also has the potential for brute force or key compromises.

Port 80 – hosts web services but has risks such as outdated modules or directory traversal.

SEARCHSPOIT

Searchsploit was used to research the vulnerabilities.

searchsploit proftpd 1.3.3c



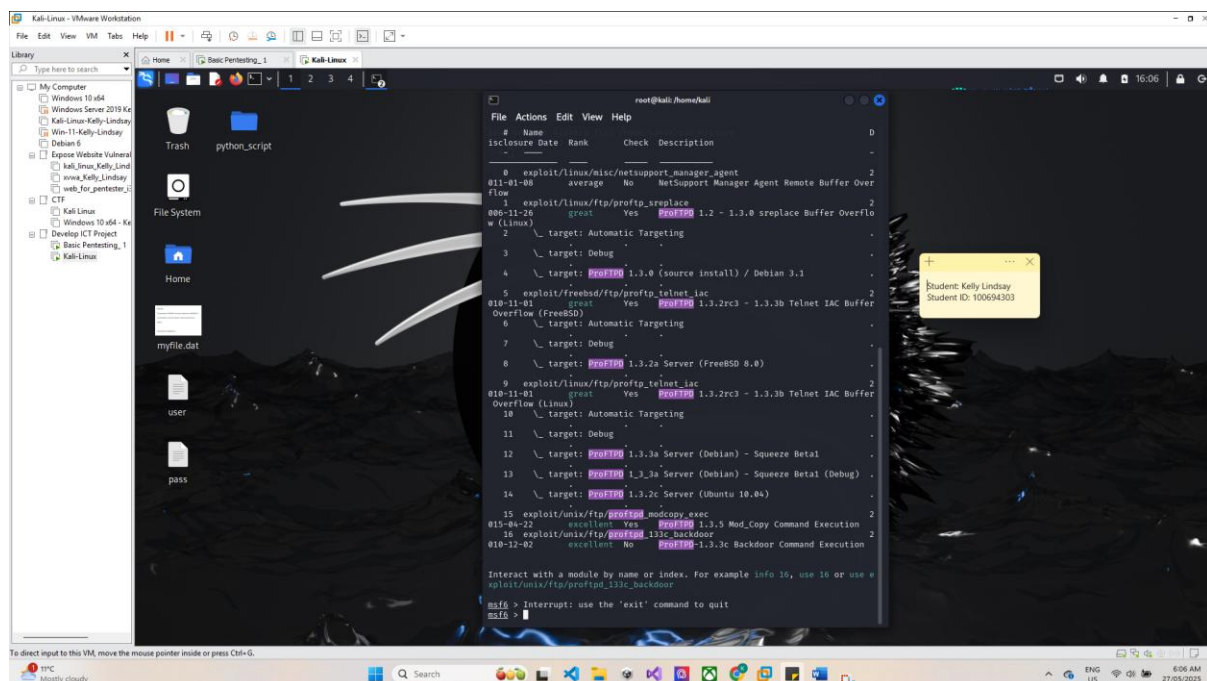
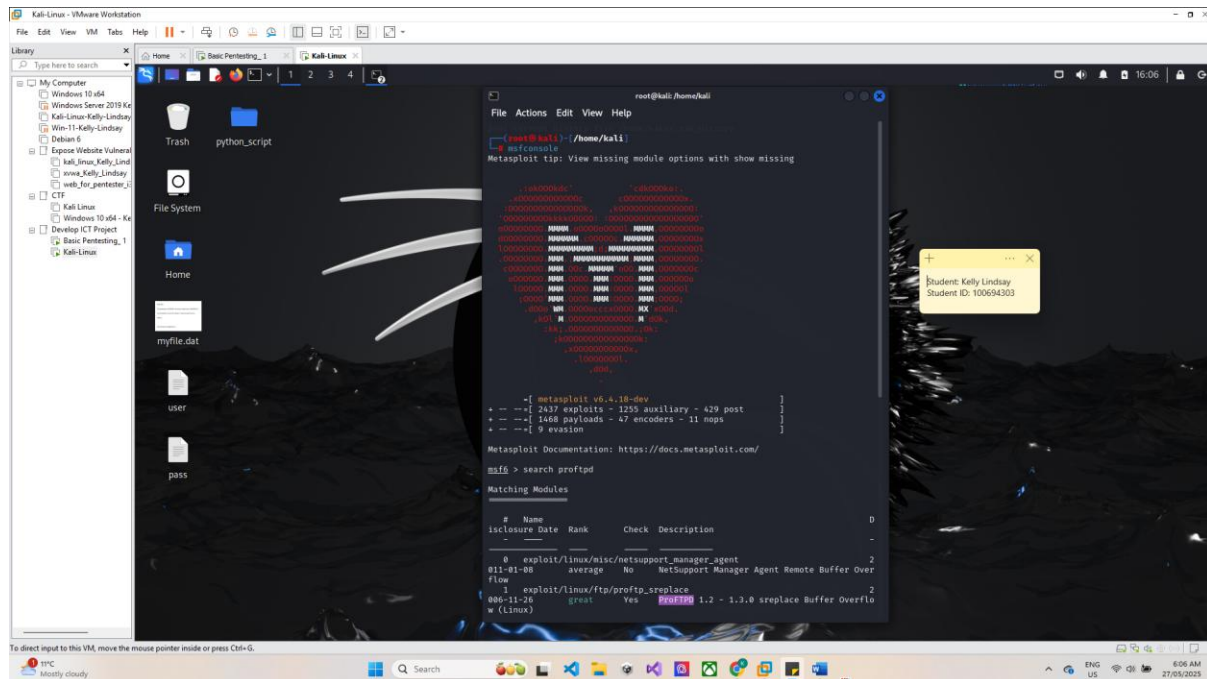
METASPLOIT-FRAMEWORK

The tester decided to pursue exploitation of port 21/tcp - FTP - ProFTPD 1.3.3c.

Metasploit was used by running:

msfconsole

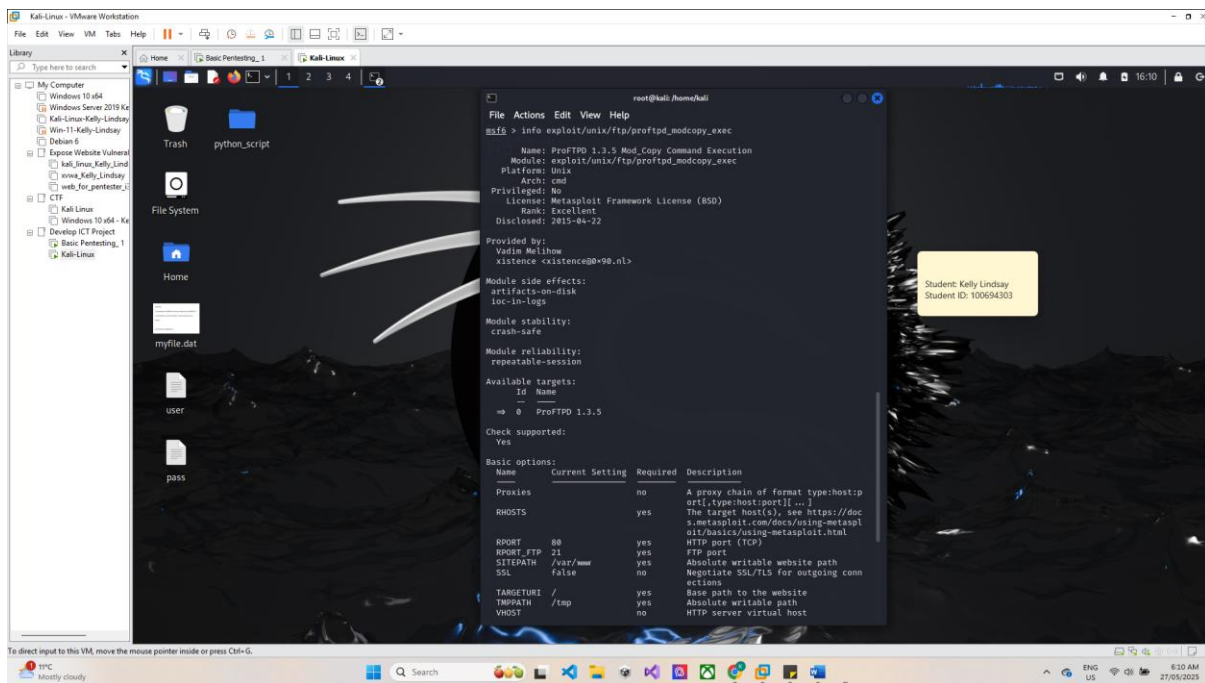
search proftpd

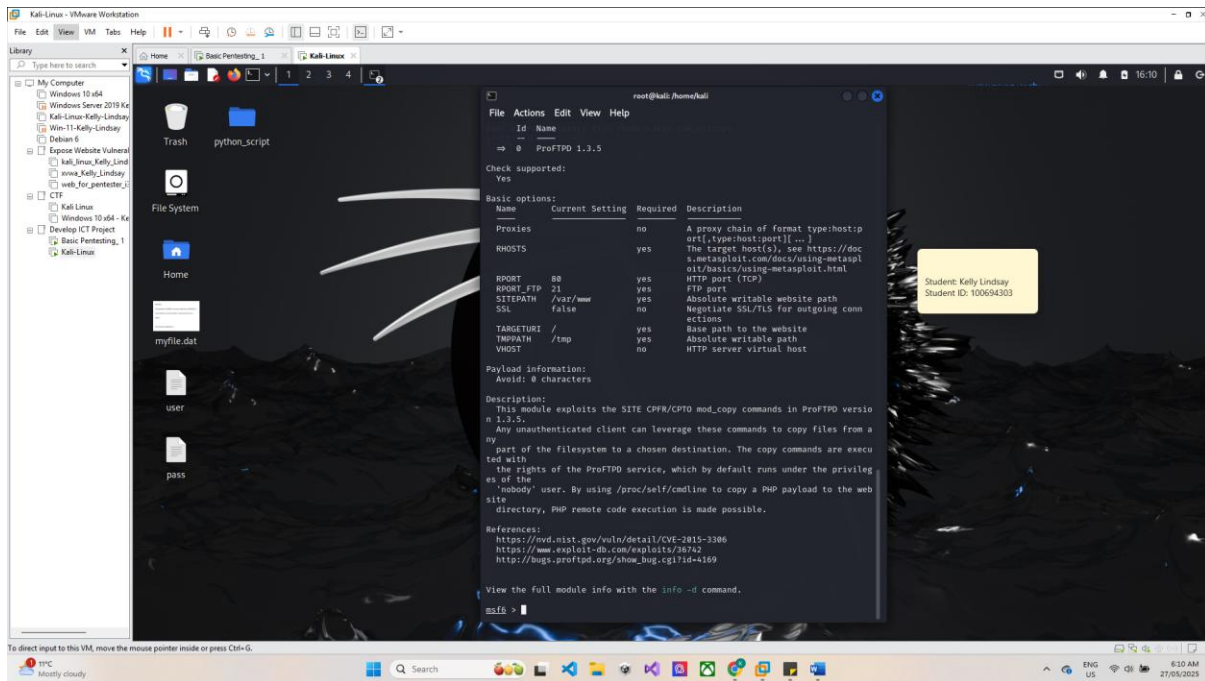


EXPLOITATION PHASE

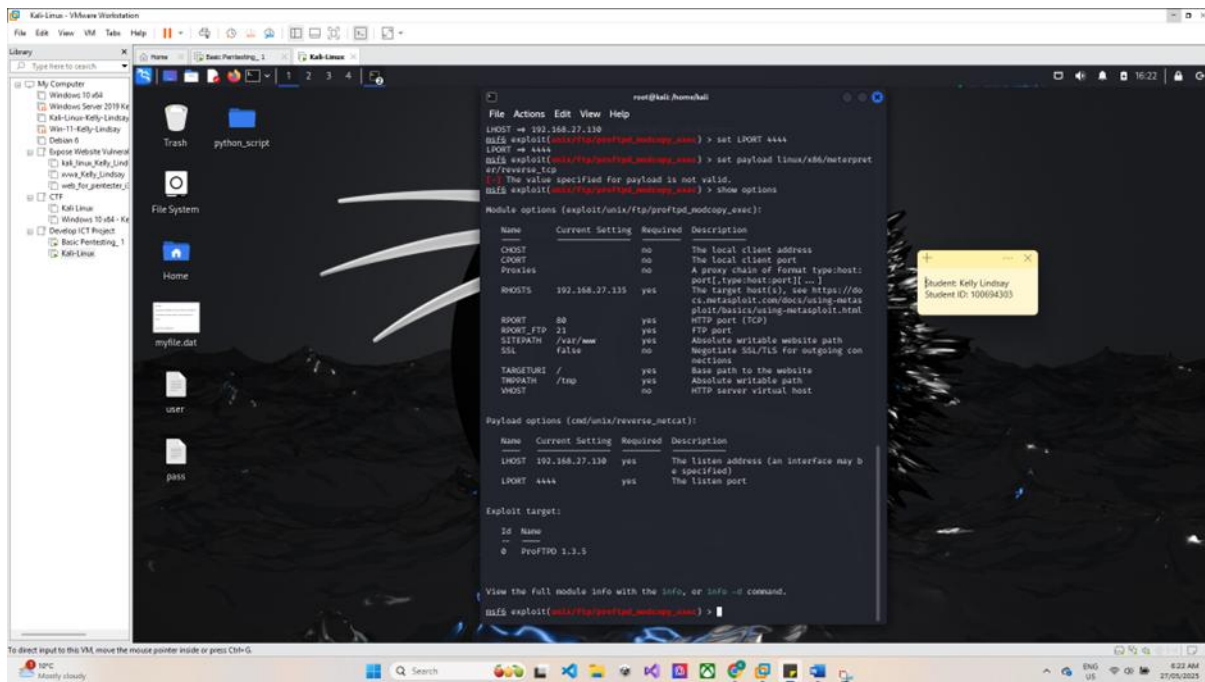
In the exploitation phase, the `exploit/unix/ftp/proftpd_133c_backdoor` module was used to exploit port 21.

The ProFTPD version 1.3.3c has a known backdoor due to a compromised source-code distribution of ProFTPD, where a malicious payload allows unauthenticated remote code execution. When triggered, the backdoor spawns a shell on the target system, typically running with the same privileges as the ProFTPD service, often as root or as a privileged user.





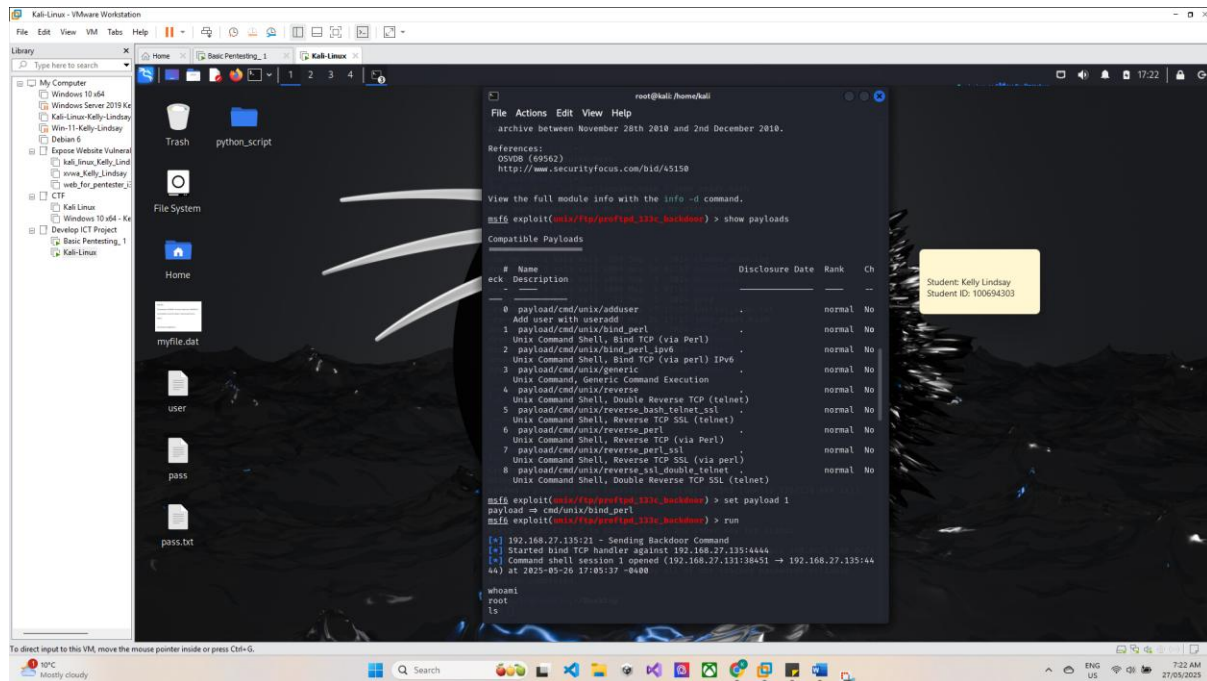
run exploit/unix/ftp/proftpd_133c_backdoor



Configured exploit/unix/ftp/proftpd_133c_backdoor to ensure target of RPORT 21 and RHOSTS 192.168.27.135

PAYLOADS

The selected payload, payload 1, was selected as it provided a direct interactive shell on the target system, which allowed for immediate command execution without needing to upload or stage more complex payloads.



IDENTIFY ROOT ACCESS

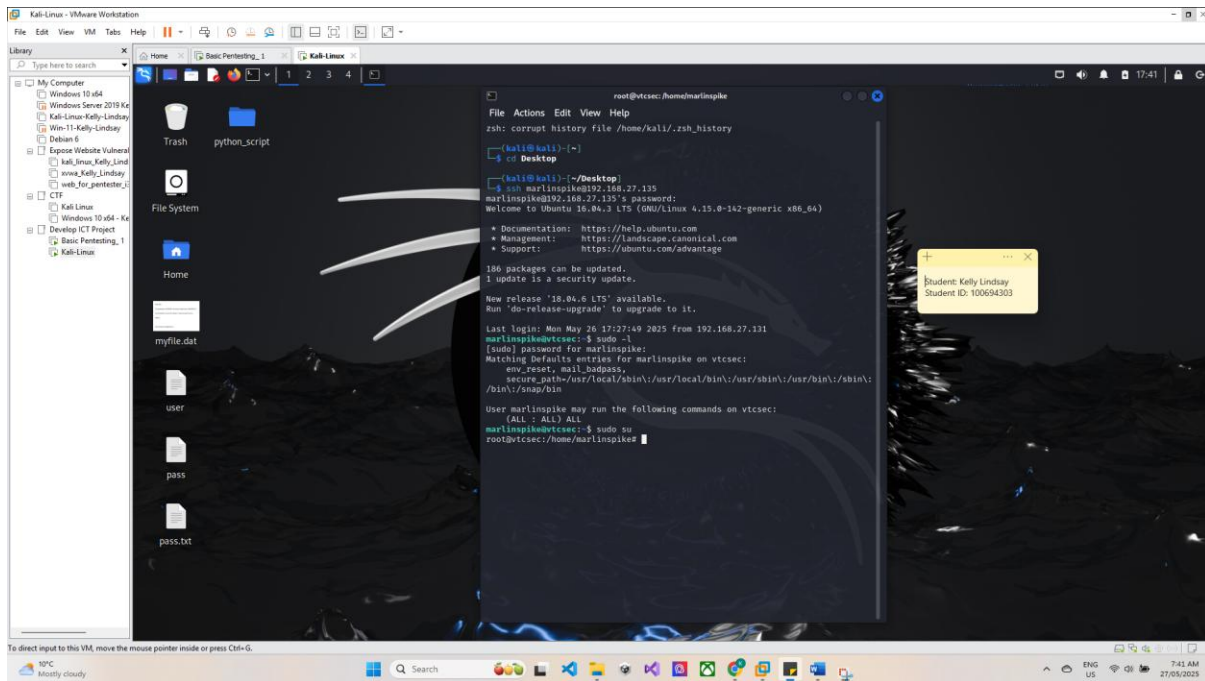
The payload allowed the tester immediate root access. This access allowed the tester to run the following commands:

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

```
cat /etc/passwd
```

```
cat /etc/shadow
```

This provided the tester with a hash for the user marlinspike.



Testing on the vulnerable server could also be done to prove this password is correct and show privilege escalation.

